

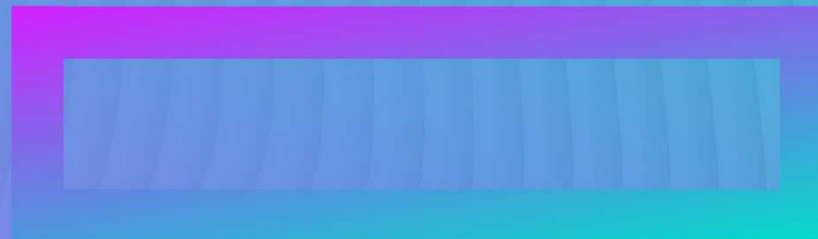
Hewlett Packard
Enterprise

THE IMPORTANCE OF FINDING SECRETS IN YOUR SOURCE CODE

Product Security Office

May 2025

1.01



TRAINING SLIDE OVERVIEW

- What is a secret?
- Looking for and auditing for secret leaks in your source and logs
- Using trivy – a popular Open Source secret scanner
- Available Options
- More Information



SECRET MANAGEMENT

Anything used to gain access to another system is a 'secret' – these can include:

- Private Keys
- HMAC salts
- Passwords
- Unexpired tokens such as JWT token

Secrets with value should never be checked in as source – it is not uncommon though for test harnesses to contain test keys and tokens which are not used for production which can be checked in. Generally, they also should be not used on the command line as well – since this information is saved.



CHECKING FOR SECRETS IN YOUR SOURCE CODE

Generally – you should store all secrets in HPE’s corporate Hashicorp Vault.

For open source – a great option is adding trivy (<https://trivy.dev/latest/getting-started/installation/#github-release-official>) to your CI pipeline along with the existing static analysis to detect secrets automatically. There are signed repositories available for RPM and Debian-based systems.

When scanning and auditing for secrets – do not forget to examine screen output and logs as well.



USING TRIVY

After installing trivy, the default for any scan is to print but not report an error code on a secret found, for instance, scanning some nginx test harnesses with test secrets:

```
leep@elko:~$ trivy fs
./go/pkg/mod/github.com/docker/distribution@v2.8.3+incompatible/contrib/docker-
integration/nginx
2025-05-07T20:04:51Z      INFO      [vuln] Vulnerability scanning is enabled
2025-05-07T20:04:51Z      INFO      [secret] Secret scanning is enabled
2025-05-07T20:04:51Z      INFO      [secret] If your scanning is slow, please try '--scanners
vuln' to disable secret scanning
2025-05-07T20:04:51Z      INFO      [secret] Please see also
https://aquasecurity.github.io/trivy/v0.55/docs/scanner/secret#recommendation for faster
secret detection
2025-05-07T20:04:51Z      INFO      Number of language-specific files          num=0
```

```
ssl/registry-ca+client-key.pem (secrets)
```

```
Total: 1 (UNKNOWN: 0, LOW: 0, MEDIUM: 0, HIGH: 1, CRITICAL: 0)
```

```
HIGH: AsymmetricPrivateKey (private-key)
```

```
...
```

The return value from the scan is 0. The output can be parsed with shell tools to count/find changes.



WHERE TO KEEP SECRETS

IT Hosted Hashicorp Vault

Tied exclusively to internal Github orgs – this allows secrets to be shared in a GUI or through a CLI accessed through a Github access token.

Pros

- Easier to handle complex secrets
- Works outside the Github ecosystem
- Provides a shared GUI for things like passwords

Cons

- Requires an internal Github organization to manage access and uses Github tokens, which are tied to a certain user and expire
- Not impossible for malicious external Actions or build tools to harvest secrets with the needed Github token

Github Secret Manager

Tied to a project or organization – this stores secrets securely and adds them to the runner environments.

Pros

- Simple – tokens are just ‘there’
- Commonality – many developers already are familiar with this process
- Not human readable

Cons

- Requires use of runners
- Complex secrets are awkward to access (like private keys)
- Not impossible for malicious external Actions or build tools to harvest secrets



OTHER TOOLS FOR SECRETS

- There are other applications available either for fee or built into other environments.
 - All cloud hosts provide secret management tied to your organization/project (Secret Manager in GC for instance)
 - Commercial software such as Bitwarden can be purchased per organization for cases where Hashicorp Vault is not a good solution
 - Runtime environments such as Kubernetes and Docker Swarm also provide secret management for running applications built-in



LEARN MORE

- <https://docs.github.com/en/actions/security-for-github-actions/security-guides/using-secrets-in-github-actions>
- <https://github.hpe.com/Vault/Wiki/wiki>

